

Multi-Platform GRC Orchestration Project Documentation

Phase Focus: Day 1 — Jira ISO Internal Audit Engine Configuration

Date: June 25, 2026

Target Framework: ISO/IEC 27001:2022 (ISMS)

Audience: GRC Operations / GRC Analyst (2-3 Yrs Exp)

1. EXECUTIVE SUMMARY

The operational bottleneck of most corporate GRC programs lies in audit execution. While legacy teams rely on disconnected, static spreadsheets to track control evidence, this phase establishes an agile, audit-ready **Internal Audit Workspace** within **Jira Software**.

By transforming static ISO 27001 clauses into actionable, tracked Jira issues, we establish absolute ownership, automated reminders, and centralized evidence collection. This forms the operational workflow engine that coordinates and feeds milestone statuses into our master ServiceNow compliance database.

2. THE GRC CHALLENGE: THE FAILURE OF SPREADSHEET AUDITS

Before configuring Jira, compliance tracking suffered from classic legacy spreadsheet vulnerabilities:

- **Zero Accountability:** No automated mechanism to assign specific compliance evidence collection to technical infrastructure owners with hard deadlines.
- **Evidence Decentralization:** Audit artifacts (screenshots, configurations) scattered across emails, chat channels, and local drives rather than paired with the target control.
- **Lack of Velocity Tracking:** Executive leadership had no real-time transparency into whether the internal audit project was 10%, 50%, or 90% complete.

3. JIRA WORKSPACE ARCHITECTURE & CONFIGURATION

To match the operational realities of a security team, Jira was configured as a structured compliance tracker rather than a standard software development board:

- **Project Design:** Jira Work Management (Company-Managed project structure).
- **Issue Type Schema:** Custom-tailored hierarchy to split requirements cleanly:
 - *Epic:* Structured to represent macro ISO 27001 Domains (e.g., Domain 5: Organizational Controls, Domain 8: Technological Controls).
 - *Task:* Structured to represent specific ISO Annex A control requirements requiring independent verification.

⚙️ **The Bulk Ingestion Strategy (CSV Import)**

To eliminate manual data entry, a pre-structured CSV control matrix containing the ISO 27001 Annex A clauses was engineered for bulk ingestion using the Jira Advanced CSV Import Tool. Controls were strategically batched into two core focus areas:

- 1. **Domain 5 (Organizational):** Used to track high-level policy guidelines (e.g., A.5.1 Policies for Information Security).
- 2. **Domain 8 (Technological):** Used to track technical cloud infrastructure metrics (e.g., A.8.15 Access Rights, A.8.24 Use of Cryptography).

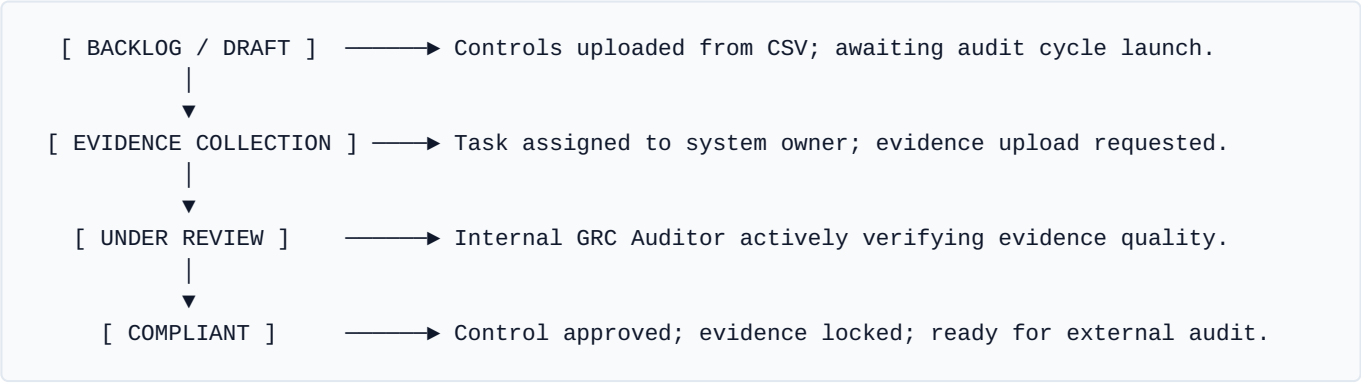
🗺️ **Data Field Mapping Matrix**

During the import setup phase, raw spreadsheet columns were mapped programmatically to native Jira fields to maximize layout cleanliness and ease of searching:

Source CSV Column	Destination Jira Field	Purpose / Operational Value
Control ID (e.g., A.5.1)	`Issue Summary (Prefix)`	Allows immediate alphanumeric sorting and filtering during audit standups.
Control Name	`Issue Summary`	Provides a clear title stating the explicit compliance expectation.
Control Text / Objective	`Description`	Provides the exact criteria the engineer must satisfy to pass the internal audit.
Control Category	`Component`	Automatically routes issues to specific team queues (e.g., "Legal/HR" vs. "Cloud security DevOps").
Audit Status	`Status`	Maps directly to the compliance verification lifecycle stages.

4. OPERATIONAL LIFECYCLE & WORKFLOW DESIGN

Every ingested ISO control was automatically funneled into a strict, four-stage compliance workflow. This eliminates ambiguity regarding whether an asset has been formally verified:



5. DAY 1 CURRENT WORKSPACE POSTURE

The table below reflects the state of the active Jira database immediately following the bulk migration on Day 1:

Key / ID	Summary	Domain / Component	Target Owner	Status
ISO-A.5.1	Policies for Information Security	Domain 5 (Organizational)	GRC/ Compliance Lead	In Progress
ISO-A.8.1	User Endpoint Devices	Domain 8 (Technological)	IT Support Operations	Backlog
ISO-A.8.15	Access Rights (AWS IAM Review)	Domain 8 (Technological)	Cloud Security DevOps	In Progress
ISO-A.8.24	Use of Cryptography (KMS/S3)	Domain 8 (Technological)	Cloud Security DevOps	Backlog

6. STRATEGIC INTEROPERABILITY (THE SERVICENOW BRIDGE)

To prepare for the Day 2 and Day 3 architecture, the Jira project was optimized to operate as a complementary partner to ServiceNow IRM:

- **Jira's Role:** Acts as the decentralized **action layer** where IT and Security engineers work daily to assign tasks, leave comments, and upload documentation.
- **ServiceNow's Role:** Acts as the centralized **governance layer** where leadership monitors overall framework compliance scores, enterprise risks, and official regulatory mappings.

Analyst Insight: This structural foundation guarantees that when we execute automated attestations later in ServiceNow, we can point directly to an active, assigned tracking ticket in Jira as our system of operational record, saving time for both engineers and auditors.